



GDRock Breach Response Pack

72-hour GDPR obligation · Copy-paste emails · Regulator links · v2.0

■ 72 HOURS

Under GDPR Art. 33, you must notify your supervisory authority of a personal data breach **within 72 hours** of becoming aware of it. If notification is delayed, you must give reasons. This pack walks you through every step.

A · Internal Incident Record (fill within 6 hours)

Complete this as soon as a breach is suspected. This is your internal evidence log — keep it confidential.

Field	Example / Instructions
Discovery date & time	2026-06-20 14:30 UTC
Reported by	Name & role of person who discovered the breach
Nature of breach	Unauthorised access / accidental disclosure / ransomware / lost device / other
Systems / data affected	Customer email list in CRM — approx. 1,240 records
Data categories affected	Names, email addresses (no financial data, no passwords)
Approx. number of records	1,240 data subjects affected
Likely consequences	Phishing risk, spam; no financial harm identified
Immediate actions taken	Server access revoked, admin passwords reset, firewall patched
DPO / Privacy contact notified	Name · Date · Time
Breach contained by	Date & time containment confirmed
72-hour deadline	Insert: discovery time + 72 h

B · Email to Supervisory Authority (≤ 72 h)

Send to your lead supervisory authority. Use the country where your EU establishment is, or if none, where most affected data subjects are located.

Country	Authority	Notification portal / email
---------	-----------	-----------------------------

France	CNIL	https://notifications.cnil.fr · notification@cnil.fr
Germany (NRW)	LfDI NRW	https://www.ldi.nrw.de · poststelle@ldi.nrw.de
Netherlands	Autoriteit Persoonsgegevens	https://autoriteitpersoonsgegevens.nl · meldpunt@autoriteitpersoonsgegevens.nl
Ireland	DPC	https://www.dataprotection.ie · info@dataprotection.ie
Spain	AEPD	https://sedeagpd.gob.es
Italy	Garante	https://www.garanteprivacy.it
All EU + EEA	Full list	https://edpb.europa.eu/about-edpb/about-edpb/members_en

Email Template — Supervisory Authority

Subject: Personal data breach notification – {{STORE_NAME}}

Dear Sir / Madam,

We wish to notify you of a personal data breach under Article 33 GDPR.

1. NATURE OF BREACH

{{Describe: e.g. Unauthorised access to customer database via compromised admin credential.}}

2. CATEGORIES & APPROXIMATE NUMBER OF DATA SUBJECTS

{{e.g. Approx. 1,240 customers – names and email addresses only.}}

3. CATEGORIES OF PERSONAL DATA CONCERNED

{{e.g. Name, email address. No financial data, health data, or passwords were affected.}}

4. LIKELY CONSEQUENCES

{{e.g. Affected individuals may receive phishing emails. No financial harm is anticipated.}}

5. MEASURES TAKEN OR PROPOSED

{{e.g. Admin access credentials reset, firewall rule updated, affected users notified, external security review commissioned.}}

6. TIMELINE

Breach discovered: {{DATE & TIME}}

Breach contained: {{DATE & TIME}}

This notification: {{DATE & TIME}}

7. CONTACT

Data Protection Officer: {{DPO_NAME}}

Email: {{DPO_EMAIL}}

Phone: {{DPO_PHONE}}

We will provide a full follow-up report within 30 days if further information is available.

Kind regards,

{{DPO_NAME}}

{{STORE_NAME}}

C · Customer Notification Email (≤ 72 h, if high risk)

Required under GDPR Art. 34 only if the breach is **likely to result in high risk** to data subjects. When in doubt, notify — it demonstrates good faith.

Subject: Important security notice regarding your account at {{STORE_NAME}}

Hi {{FIRST_NAME}},

We want to be open and transparent with you about a recent security incident.

WHAT HAPPENED

On {{DATE}}, we discovered that some of your personal data – specifically your name and email address – was accessed without authorisation. No passwords or payment details were involved.

WHAT WE HAVE DONE

- Secured the server and reset all administrative access credentials
- Reported the incident to the EU data protection authority
- Implemented additional security monitoring
- Launched an independent security review

WHAT YOU SHOULD DO

- Be cautious of unexpected emails asking for personal information
- Do not click links in emails you weren't expecting
- If you notice anything suspicious, contact us immediately

We sincerely apologise for any concern this may cause. The security of your data is our highest priority.

Questions? Reply to this email or contact: support@{{STORE_DOMAIN}}

Stay safe,

{{STORE_NAME}} Team

Data Protection Officer: {{DPO_EMAIL}}

D · Post-Breach Action Checklist

Timeline	Action	Done
0–6 h	Complete Internal Incident Record (Section A above)	■
0–6 h	Contain the breach — revoke access, patch vulnerability, isolate systems	■
6–24 h	Assess severity and likely consequences for data subjects	■
24–48 h	Prepare supervisory authority notification (Section B above)	■
≤72 h	Submit notification to supervisory authority	■
≤72 h	Notify affected customers if high risk (Section C above)	■
72 h+	Commission external security review or penetration test	■
72 h+	Review and update security policies, DPAs, and staff training	■
30 days	Submit follow-up report to supervisory authority if new info available	■

Ongoing	Document lessons learned; update Incident Record with resolution details	■
---------	--	---